

Tutorial Week 4

COM398

Introduction to John the Ripper

Password Cracking in System Security/ Cybersecurity

- **What is John the Ripper ?:** A widely used open-source Password cracking tool designed for detecting weak passwords in systems. Initially developed for UNIX-based systems. It now supports a verity of operating systems.
- **Role in System/Cybersecurity:** Used for testing password strength in a controlled environment. Helps in identifying vulnerabilities by cracking password hashes using various methods like dictionary attacks.
- **Supported Hash Types:** Supports multiple hash formats including MD5, SHA-256,NTLM, and more, making it versatile for various penetration testing scenarios.

Installation and Setup

Setting up John he Ripper

Installation:

- First, you'll need to download and install John the Ripper. It is available for Linux, MacOS, and Windows. On Linux, you can typically install it through your package manager, for example on Kali:

```
sudo apt-get install john
```

Once installed, the main executable is 'john' and will be available in your PATH. (ON KALI LINUX JOHN IS ALREADY AVAILABLE). You can skip the installation step.

Creating Password Hashes

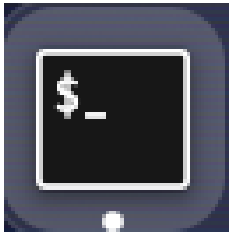
Step by step Guide

- Before cracking, you need some password hashes to target. Here are some ways to obtain hashes:
  - Extract hashes from a system password file like /etc/shadow
  - Use a tool like zip2john against a password protected archive
  - Capture network authentication hashes with a sniffer
  - Extract hashes from system memory or databases

Example – Cracking a password Hash

A step-by-step Tutorial

- Click on the Terminal in Kali Linux as

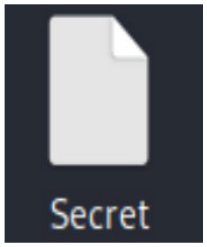


- Create a test file using the following command

Command:

```
echo "secret data" > secret.txt
```

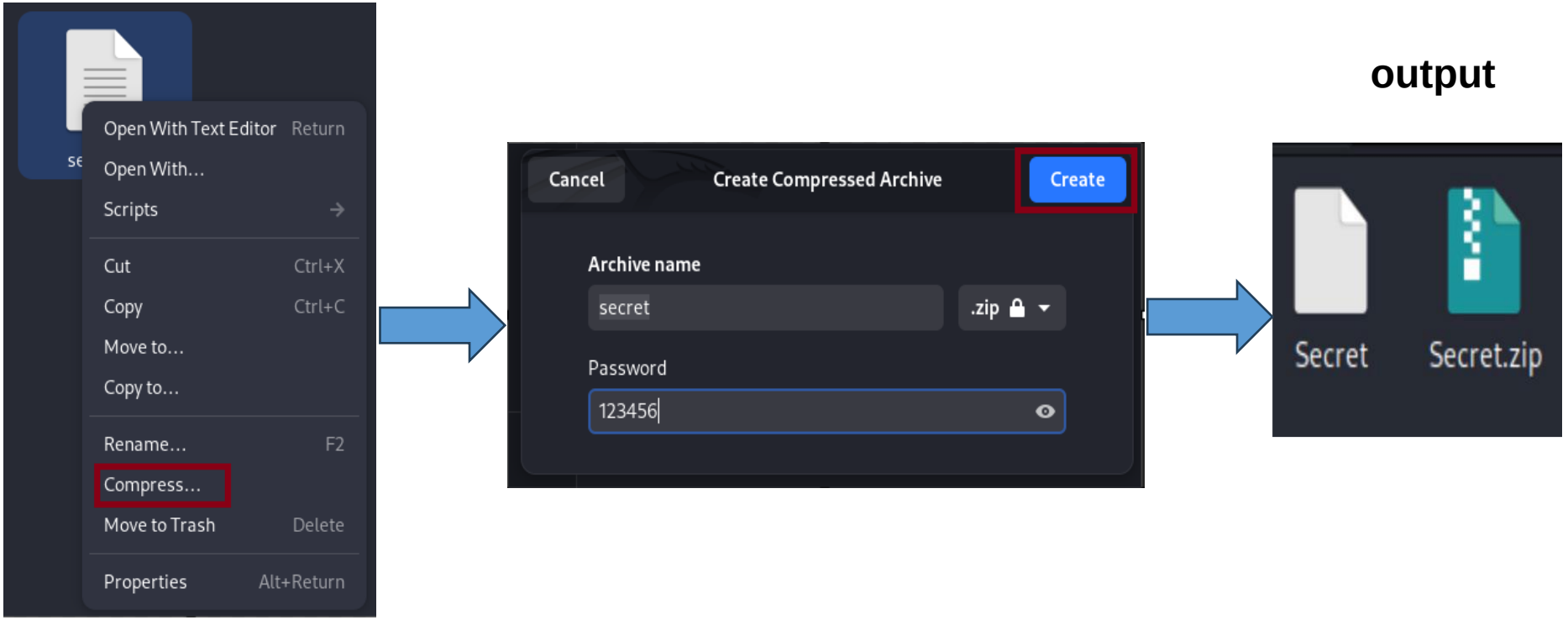
Output:



Example – Cracking a password Hash

A step-by-step Tutorial

- Now create a zip archive secured with password '123456'
  - *Right click* on *secret.txt* file and select *compress* and then enter the *password* as shown



Example – Cracking a password Hash

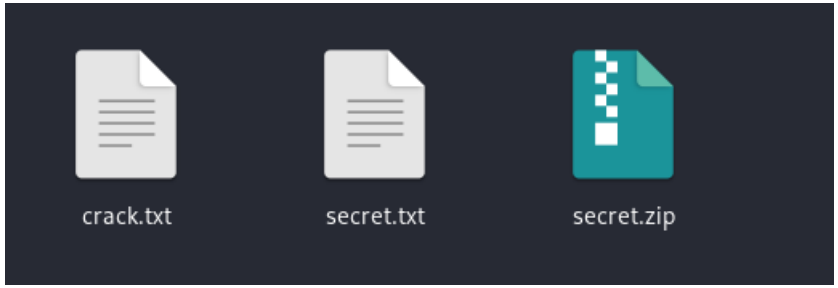
A step-by-step Tutorial

- Now Calculate the Hash of the secret.zip file using the following command

Command



output



This will create a file ‘crack.txt' containing the hash of the ZIP file to target for cracking.

Example – Cracking a password Hash

Cracking the Hashes with John

- Now run John against the hashed values in crack.txt.
- Let's crack the password using John the Ripper tool as shown in following command:

Command

```
┌──(kali㉿kali)-[~/Desktop/Password]
└─$ john --format=zip crack.txt
```

output

```
kali@kali: ~/Desktop/Password
└─$ zip2john secret.zip > crack.txt

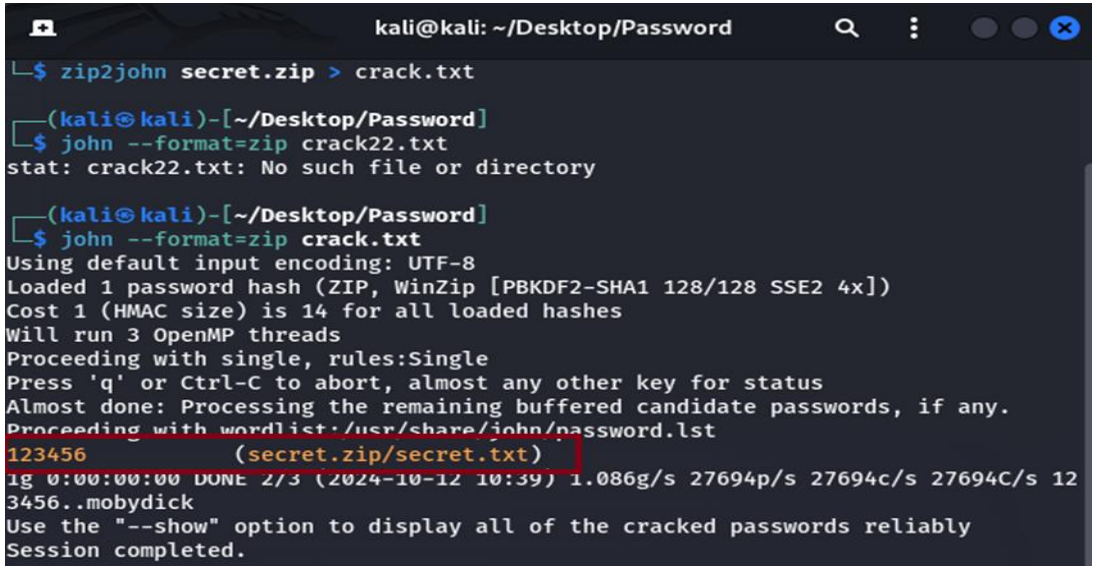
┌──(kali㉿kali)-[~/Desktop/Password]
└─$ john --format=zip crack22.txt
stat: crack22.txt: No such file or directory

┌──(kali㉿kali)-[~/Desktop/Password]
└─$ john --format=zip crack.txt
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 128/128 SSE2 4x])
Cost 1 (HMAC size) is 14 for all loaded hashes
Will run 3 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
123456           (secret.zip/secret.txt)
1g 0:00:00:00 DONE 2/3 (2024-10-12 10:39) 1.086g/s 27694p/s 27694c/s 27694C/s 12
3456..mobydick
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Example – Cracking a password Hash

Cracking the Hashes with John

- To learn that the command needs to specify the format of the package/file.
- In this example, it is a zip package/file so we use the option --format=zip, if it was .rar package/file then the format will be --format=rar.



After the command you will see the magic as shown in the above output

Ethical Considerations – John the Ripper

Lega and Ethical use in System Security /Cybersecurity



Authorized Use Only
Always obtain permission before testing systems or cracking passwords. Unauthorized use can lead to severe legal consequences.



Focus on Security Testing
Use John the Ripper to improve security by identifying vulnerabilities in systems you are authorized to test, like auditing corporate password policies.



Privacy Respect
Avoid accessing or distributing cracked passwords or sensitive information. Ethical hacking aims to secure, not exploit.

Real-World Use Cases – John the Ripper

Applications in System Security/ Cybersecurity



Penetration Testing
Used by security professionals to test the strength of passwords in corporate environments, ensuring compliance with security policies.



Forensic Investigations
Helps in digital forensics by recovering passwords for encrypted files or user accounts during legal investigations.

Educational Use
Used in cybersecurity training and ethical hacking courses to demonstrate password vulnerabilities and the importance of strong password practices.

Conclusion

Key Takeaways on using John the Ripper

- **Effective Security Tool:** John the Ripper remains a powerful asset for identifying weak passwords and improving overall security posture in various environments.
- **Ethics and Responsibility:** It is crucial to use John the Ripper responsibly and within legal boundaries, focusing on strengthening security rather than exploiting vulnerabilities.
- **Continued Relevance:** As password-based authentication remains common, tools like John the Ripper are vital for ongoing security assessments and training.



https://www.pinterest.com/pin/791015122082029627/

Thanks!